

NIST SP 800-53 Rev. 5 Gap Assessment Report

Prepared for Northstar, Inc. (Moderate Baseline, Tailored) | mock engagement, portfolio demonstration

Executive Summary

Northstar, Inc. completed a SOC 2 Type I readiness engagement earlier this year to satisfy an enterprise customer requirement. Since then, Northstar has been approached by a prospective state government agency customer whose procurement process requires vendors to demonstrate alignment with NIST SP 800-53 controls at the Moderate impact baseline. This is a common requirement for SaaS vendors selling into the public sector who are not pursuing full FedRAMP authorization; the agency's own risk process still expects evidence of a comparable control set.

This assessment builds directly on the SOC 2 readiness work rather than starting over. Several SOC 2 remediation items (MFA enforcement, GitHub branch protection, an initial incident response plan, a tested backup restore, and adoption of SSO) are already in place and materially reduce the gaps that would otherwise appear under NIST's broader control set. The SOC 2 engagement was scoped narrowly to the nine Security Common Criteria categories. NIST SP 800-53 Moderate introduces additional control families (contingency planning, security awareness training, configuration management baselines, and formal system security planning) that were out of scope for SOC 2 but are now required.

Key priorities, in order of risk:

- Adopt automated vulnerability scanning and a defined remediation SLA, flagged as a watch item in the SOC 2 report and still unaddressed.
- Establish a formal Contingency Plan (CP) beyond the single backup restore test already performed, including a defined Recovery Time Objective (RTO) and Recovery Point Objective (RPO).
- Stand up a baseline security awareness training program for all employees and contractors with system access.

This report includes a scoping memo, a control family gap analysis tailored to Northstar's environment, a prioritized risk register, a phased remediation roadmap, and two NIST-specific sample artifacts: a System Security Plan (SSP) excerpt and a Plan of Action & Milestones (POA&M) template. With focused effort over the roadmap's 12-week horizon, Northstar will have a documented control set suitable to present to the prospective agency customer as part of its vendor risk review.

1. Scoping Memo

Client: Northstar, Inc.

Objective: A prospective state government agency customer has indicated that vendor selection requires evidence of security controls aligned to NIST SP 800-53. Northstar is not pursuing a formal FedRAMP Authorization to Operate (ATO) at this stage; that process requires sponsorship by a federal agency and an accredited Third Party Assessment Organization (3PAO), and is not proportionate to a single state-level procurement. Instead, this engagement produces a self-attested gap assessment and control documentation set that Northstar can present during the agency's vendor risk review.

Relationship to prior SOC 2 engagement: This assessment does not repeat the SOC 2 gap analysis. Where a NIST control maps directly to a SOC 2 Common Criteria control already remediated (e.g., MFA under AC/IA, branch protection under CM), that control is marked satisfied here and cross-referenced rather than re-assessed from scratch.

Baseline Selection: Moderate, Tailored

FIPS 199 defines impact levels (Low, Moderate, High) based on the confidentiality, integrity, and availability impact of a breach. Northstar processes customer business data and billing information but not classified, life-safety, or high-volume PII data. A compromise would cause serious but not catastrophic harm to the agency's operations or Northstar's customers, which places Northstar at the **Moderate** impact level. Moderate is also the baseline most public-sector procurement teams expect from a SaaS vendor by default, even outside formal FedRAMP.

The Moderate baseline is **tailored** for Northstar's environment: controls that presuppose physical data center operations (e.g., Physical and Environmental Protection, or PE) or formal independent assessment and continuous monitoring infrastructure (Assessment, Authorization, and Monitoring, or CA) are scoped out, since Northstar runs entirely on AWS-managed infrastructure and is not seeking a formal ATO. This assessment focuses on the twelve control families most applicable to a cloud-native SaaS company: AC, AT, AU, CM, CP, IA, IR, PL, RA, SA, SC, and SI.

System Description Boundary

In scope: production AWS environment (EC2, RDS, S3), the application codebase and CI/CD pipeline (GitHub), single sign-on and identity provider, employee access to customer data, and third-party vendors that touch customer data (Stripe for billing). **Out of scope:** internal tools that do not touch production systems or customer data, and any physical office environment controls, as Northstar is fully remote.

Note on Assessment Type

This is a self-assessed gap analysis, not an independent third-party audit or a FedRAMP-style security assessment. It is intended to give Northstar leadership a clear, evidence-based picture of its control posture and a credible set of artifacts to share with a prospective customer during vendor risk review, not a formal authorization decision.

2. Control Family Gap Analysis

Each control family below was assessed against Northstar's current environment. Rather than listing every control in the Moderate baseline (222 controls and enhancements across these twelve families before tailoring), this analysis summarizes the assessed posture per family and details the representative controls that drive the highest risk or the most remediation effort. This mirrors how a real gap assessment is scoped for a small organization: broad coverage at the family level, depth where it matters.

Assessment Depth and Sampling

Consistent with the depth-and-coverage concept used in SP 800-53A, this assessment applied full, control-by-control testing to a risk-based sample of 2-3 controls per family (roughly 25 controls total), selected for the highest likely risk or remediation effort. Controls outside this sample were reviewed at the family level; no additional material findings were identified in this pass, but they have not been individually tested to the same depth as the sampled controls listed below. A full engagement would expand this sample as time and budget allow.

Family	Controls Assessed	Satisfied	Partial	Gap	Priority
AC: Access Control	39	15	16	8	High
AT: Awareness & Training	6	0	0	6	Medium
AU: Audit & Accountability	16	5	8	3	Medium
CM: Configuration Management	24	6	8	10	High
CP: Contingency Planning	23	2	6	15	High
IA: Identification & Authentication	24	15	7	2	Low
IR: Incident Response	13	4	6	3	Medium
PL: Planning	7	1	2	4	High
RA: Risk Assessment	10	2	4	4	Medium
SA: System & Services Acquisition	17	5	5	7	Medium
SC: System & Communications Protection	25	12	9	4	Low
SI: System & Information Integrity	18	3	6	9	High

Counts are pulled directly from the SP 800-53B Moderate baseline tables for each family (base controls plus applicable enhancements), tailored to Northstar's environment; families such as PE and CA are excluded entirely as documented in the Scoping Memo.

AC: Access Control

Northstar's SOC 2 remediation already addressed the highest-risk access gaps (MFA, offboarding, least-privilege intent). The remaining NIST-specific gaps are about formalizing and periodically re-verifying what is currently informal practice.

Control	Current State	Gap	Remediation
AC-2 Account Mgmt	Onboarding/offboarding process documented under the SOC 2 Access Control Policy; access revoked within 24 hours of departure.	No periodic (e.g., quarterly) recertification of active accounts against current role requirements; this scope also includes service accounts and API keys, which have no documented process for periodic review or disabling when no longer in use.	Add a recurring account recertification step to the existing monthly access review, explicitly scoped to cover service accounts and API keys alongside human user accounts.
AC-2(1) Automated Acct Mgmt	SSO now provisions and deprovisions accounts automatically across the tools connected to it.	Not every tool is behind SSO yet, so account lifecycle management is automated for some systems but still manual for others.	Prioritize bringing remaining tools under SSO; until then, document the manual process for the tools not yet covered.
AC-6 Least Privilege	Role-based provisioning exists informally; access request process requires written approval.	No documented least-privilege baseline per role; privileged (admin) AWS/GitHub accounts are not separately inventoried or reviewed on a shorter cycle.	Define role-based access baselines; inventory and review privileged accounts monthly, separate from standard user review.
AC-6(9) Log Privileged Fn Use	AWS CloudTrail and GitHub audit logs already capture privileged actions (e.g., IAM changes, admin merges), per the SOC 2 CC4 finding.	None identified; existing logging already meets this requirement.	None required; maintain current logging configuration as part of the monthly review cadence.
AC-17 Remote Access	Fully remote workforce; SSO now in place for centralized authentication across core tools.	No formal remote access policy addressing device posture requirements beyond disk encryption and screen lock.	Extend the Access Control Policy to explicitly cover remote access conditions and acceptable network use.
AC-17(2) Encrypt Remote Sessions	AWS-managed TLS protects all remote sessions in transit, consistent with the SC-8/SC-13 findings.	None identified; existing encryption already meets this requirement.	None required; maintain current TLS configuration.

AT: Awareness & Training

This is a net-new family relative to the SOC 2 engagement. It is inexpensive to remediate and closes a gap that is easy for an evaluator to notice.

Control	Current State	Gap	Remediation
AT-2 Literacy Training	No formal security awareness training program exists for employees or contractors.	Entire family is a gap; this was out of scope for the SOC 2 Security criteria and has not been addressed.	Adopt a low-cost security awareness training platform (or a lightweight internally-built module) with mandatory completion at onboarding and annually thereafter.
AT-3 Role-Based Training	No role-based training for personnel with elevated access (e.g., engineers with production AWS access).	No differentiated training content for higher-risk roles.	Layer a short role-based module (secure coding basics, incident reporting) on top of the general training for engineering staff.

AU: Audit & Accountability

Logging infrastructure is already in place from the SOC 2 phase (CC4); this family is mostly about formalizing what gets logged and why, documenting how review findings are reported and escalated, and closing the gap between raw log collection and automated, correlated analysis.

Control	Current State	Gap	Remediation
AU-2 Event Logging	AWS CloudTrail and GitHub audit logging are enabled by default, capturing a broad range of system and repository events.	No formal process defines, coordinates, or documents which event types are selected for logging; no documented rationale for the adequacy of logged events to support after-the-fact investigations; no periodic review of the event-type selection itself.	Document the organization's selected event types, the rationale for each, and a defined frequency for revisiting that list (e.g., annually or after a material architecture change).
AU-6 Audit Record Review, Analysis & Reporting	AWS CloudTrail and GitHub audit logs are reviewed on a monthly cadence by the security owner under the SOC 2 roadmap.	Review findings are not consistently documented as reportable items to defined personnel or roles; there is no defined process to increase review frequency or depth in response to elevated risk or credible threat intelligence.	Define who findings are reported to and how, and document a trigger (e.g., an active threat advisory) that increases review frequency.
AU-6(1) Automated Process Integration	Log review, analysis, and reporting are performed manually by the security owner.	No automated mechanism (e.g., SIEM correlation, automated flagging) integrates the review, analysis, and reporting process.	Enable AWS GuardDuty or equivalent low-cost automated correlation; route high-severity findings to the Incident Response Lead in real time.
AU-6(3) Correlate Audit Record Repositories	CloudTrail and GitHub audit logs are reviewed independently of one another.	No correlation across repositories; findings from one log source are not cross-referenced against others to support organization-wide situational awareness.	Route both log sources into a single low-cost log aggregation tool (or a SIEM, shared with AU-6(1)) so events can be correlated across sources rather than reviewed in isolation.

CM: Configuration Management

CM-2(7) (Configure Systems and Components for High-Risk Areas) is included in the Moderate baseline but is scored Not Applicable: it addresses issuing hardened configurations to personnel traveling to high-risk locations, a scenario with no evidence of applying to Northstar's remote, cloud-native operating model. The remaining CM findings show a consistent pattern: several enhancements fail purely because the base control they extend does not exist yet, but each represents a distinct deliverable once the baseline and inventory are built, not something that gets solved automatically.

Control	Current State	Gap	Remediation
CM-2 Baseline Configuration	No documented baseline configuration for AWS resources or application environments.	Infrastructure changes are made ad hoc without a reference baseline to compare against.	Document current AWS configuration as the initial baseline (can be captured via AWS Config); require deviations to be reviewed.

Control	Current State	Gap	Remediation
CM-2(2) Automation Support for Accuracy & Currency	No baseline configuration exists to maintain.	Even once a baseline is established, there is no automated mechanism to keep it current and accurate; maintenance would be manual.	Use AWS Config rules (or equivalent) to keep the baseline automatically current rather than relying on manual updates.
CM-2(3) Retention of Previous Co nfigurations	No baseline configuration exists to version.	No prior baseline versions are retained, so there is no ability to roll back to a known-good configuration state.	Retain a defined number of previous baseline versions (AWS Config maintains configuration history natively) to support rollback.
CM-3 Config uration Change Control	Peer code review is enforced via GitHub branch protection (from SOC 2 CC8) for application code; separation of duties between authoring and deploying code is documented.	Code review does not explicitly assess security or privacy impact as a distinct step; infrastructure changes (manual AWS console changes, infrastructure-as-code) have no equivalent review or approval process at all; no formal Configuration Control Board or change record retention policy exists.	Add an explicit security/privacy impact consideration to the code review checklist; extend change control to cover infrastructure changes; document a change record retention period.
CM-8 System Component Inventory	No current, maintained inventory of system components (EC2 instances, RDS databases, S3 buckets, third-party software dependencies).	No visibility into what exists in the environment beyond institutional knowledge.	Generate an initial inventory using AWS Config or a tagging standard; keep it current as part of the monthly review cadence.
CM-8(1) Updates During Installation & Removal	No inventory exists to update.	Even once an inventory is established, there is no process to update it at the point a component is installed or removed; updates would depend on the periodic review cadence catching the change after the fact.	Trigger an inventory update as part of the provisioning/deprovisioning process itself (e.g., via AWS Config or infrastructure-as-code hooks), not only on a review schedule.
CM-8(3) Automated Unauthorized Component Detection	No automated mechanism exists to detect unauthorized hardware, software, or firmware.	Unauthorized or unapproved components (e.g., an unsanctioned AWS resource or dependency) would only surface through manual review, if at all.	Enable AWS Config rules or a software composition analysis tool to automatically detect unauthorized components and notify the security owner.

CP: Contingency Planning

This is the largest gap area. The SOC 2 engagement addressed backup *recoverability* as a one-time proof point; NIST expects an ongoing, documented Contingency Plan with defined objectives and a testing cadence.

Control	Current State	Gap	Remediation
CP-2 Contingency Plan	One backup restore test was performed as part of SOC 2 remediation (CC7), demonstrating that recovery is technically possible.	No documented Contingency Plan defining Recovery Time Objective (RTO), Recovery Point Objective (RPO), roles, or a full-scenario recovery procedure beyond a single database restore.	Draft a Contingency Plan defining RTO/RPO targets, backup scope (not just database, but configuration and application state), and named recovery roles.
CP-2(1) Coordinate with Related Plans	No contingency plan exists to coordinate.	Contingency planning is not coordinated with owners of related plans (e.g., Incident Response), beyond the informal overlap already noted in the base finding.	Once a Contingency Plan is drafted, formally coordinate its development with the Incident Response Lead and any other relevant plan owners.
CP-2(8) Identify Critical Assets	No system component inventory exists (see CM-8) to identify critical assets from.	Critical assets supporting essential business functions are not formally identified, so the Contingency Plan has no defined scope of what it needs to protect and recover.	Identify critical assets as part of building the CM-8 inventory, and carry that list into the Contingency Plan's scope.
CP-4 Contingency Plan Testing	A single ad hoc restore was performed; not repeated or scheduled.	No annual testing cadence or defined test types; results of the one restore performed were not formally reviewed, and no process exists to initiate corrective action from test findings.	Schedule an annual Contingency Plan test, distinct from the Incident Response tabletop, with a defined process to review results and track corrective actions to closure.
CP-4(1) Coordinate with Related Plans	No contingency plan testing cadence exists to coordinate.	Contingency plan testing is not coordinated with owners of related plans, so a test cannot exercise realistic cross-team scenarios (e.g., testing recovery alongside an Incident Response tabletop).	Once an annual test cadence is established, coordinate it with the Incident Response Lead so recovery and incident response are exercised together at least once.
CP-9 System Backup	AWS RDS automated backups are enabled by default; not independently verified for all data stores (e.g., application logs, S3 configuration).	No documented backup scope covering all in-scope systems, only the primary database; system documentation (policies, the SSP itself) is not backed up at all; confidentiality and integrity protections on backup data have not been independently verified.	Document backup coverage across all in-scope AWS services, not just RDS; extend backup scope to include system documentation; verify and document backup protection controls.
CP-9(1) Testing for Reliability & Integrity	One ad hoc restore was performed as part of SOC 2 remediation, touching this once.	No recurring cadence to test backup media reliability and information integrity, independent of whether a full recovery plan exists.	Add a periodic (e.g., quarterly) automated or manual backup integrity test, distinct from the annual full Contingency Plan test.
CP-9(8) Cryptographic Protection	AWS RDS backups are stored using AWS's default storage mechanisms.	No confirmation that backup data is encrypted to prevent unauthorized disclosure or modification; encryption-at-rest for backups has not been explicitly verified or documented.	Verify RDS backup encryption is enabled and document it; extend the same verification to any other backed-up data stores.

IA: Identification & Authentication

This family shows the clearest benefit of the SOC 2 remediation work already completed. MFA and SSO adoption resolve most of what would otherwise be significant gaps. IA-2(12) (Acceptance of PIV Credentials) is included in the Moderate baseline but is scored Not Applicable: PIV is a federal government credential type with no evidence of relevance to a private SaaS company. Separately, IA-2(10) (Single Sign-on) is not required at all under the Moderate baseline, but Northstar has already implemented it, worth noting as a control exceeding baseline expectations rather than a finding.

Control	Current State	Gap	Remediation
IA-2 Identification & Authentication (Org Users)	MFA is enforced org-wide (SOC 2 CC5 remediation); SSO now centralizes authentication across core tools, closing the gap the SOC 2 report flagged as a future consideration.	No documented password/credential policy for the small number of tools not yet behind SSO.	Extend the Access Control Policy with minimum credential requirements for any remaining non-SSO tools, or prioritize bringing them under SSO.
IA-2(1) MFA to Privileged Accounts	The Access Control Policy requires MFA for all accounts with access to production systems, source code, or customer data, with no privilege-tier carve-out.	None identified; existing MFA enforcement already meets this requirement for privileged accounts.	None required; maintain current MFA enforcement as part of the Access Control Policy.
IA-2(2) MFA to Non-privileged Accounts	Same Access Control Policy language applies regardless of privilege tier; MFA is required based on what an account can access, not its privilege level.	None identified; existing MFA enforcement already meets this requirement for non-privileged accounts.	None required; maintain current MFA enforcement as part of the Access Control Policy.
IA-2(8) Replay-Resistant Authentication	MFA is enforced org-wide via the organization's SSO provider.	The specific MFA factor in use (e.g., authenticator app, push notification, hardware key, or SMS) is not documented anywhere in current policy or evidence, so replay resistance cannot be confirmed.	Document the MFA factor(s) actually in use, and standardize on a replay-resistant method (app-based TOTP, push, or hardware key) if SMS is in use for any accounts.
IA-4 Identifier Management	User accounts are tied to individual identity via SSO; account authorization and assignment follow the documented AC-2 provisioning process.	No documented time period preventing reuse of identifiers (e.g., a departed employee's username or email address) before they could be reassigned to a new hire or contractor.	Define a minimum retirement period (e.g., 12 months) before any identifier can be reused, and document it as part of the offboarding process.
IA-4(4) Identify User Status	Identifiers are assigned via SSO without a distinguishing status attribute.	No process tags identifiers by organization-defined status or type (e.g., employee, contractor, vendor, service account) at the point of assignment.	Add a status/type attribute to identifiers as part of the SSO provisioning process so account type is identifiable from the identifier record itself.

IR: Incident Response

Control	Current State	Gap	Remediation
IR-8 Incident Response Plan	A written Incident Response Policy exists, defining severity classification, communication protocols, and a designated Incident Response Lead.	The plan does not define metrics for measuring incident response capability, has no documented review/approval cadence, no defined process to update the plan based on lessons learned or organizational change, and its own protection from unauthorized disclosure or modification has not been addressed.	Add a defined review cadence (e.g., annually or after any incident) with a named approver, incorporate basic metrics (e.g., time-to-detect, time-to-contain), and apply the same access restrictions used for other sensitive policy documents.
IR-3 Incident Response Testing	No incident response testing has been performed to date.	The annual tabletop exercise the IR policy itself requires has never been run, so the plan's real-world effectiveness is untested.	Run the first tabletop exercise using a realistic scenario (e.g., credential compromise via a phishing email) and document the results.
IR-3(2) Coordination with Related Plans	No incident response testing has ever been performed to coordinate.	Incident response testing is not coordinated with owners of related plans (e.g., the CP-4 Contingency Plan test), so a test cannot exercise realistic cross-team scenarios.	Once the first tabletop is scheduled, coordinate it with the Contingency Plan owner so incident response and recovery are exercised together.
IR-6 Incident Reporting	Employees are instructed to report suspected incidents to the Incident Response Lead.	No defined time period within which personnel must report a suspected incident once discovered, and no defined process for reporting incident information to external authorities (e.g., affected customers, regulators, or law enforcement) when required.	Define a maximum reporting window (e.g., within 24 hours of discovery) and document an external notification process, including named authorities/parties and the legal or contractual triggers that require it.
IR-6(1) Automated Reporting	Incident reporting is entirely manual, direct to the Incident Response Lead.	No automated mechanism (e.g., a ticketing system, chat-ops integration, or paging tool) supports incident reporting.	Route incident reports through an existing tool already in use (e.g., a dedicated Slack channel with logging, or a lightweight ticketing system) rather than informal direct contact.
IR-6(3) Supply Chain Coordination	No process exists to notify third-party providers when an incident involves their systems or components.	As a cloud-native SaaS company fully dependent on third-party infrastructure (AWS, GitHub, and other vendors), Northstar has no defined process to share incident information with a provider when an incident involves their product or service.	Add a step to the incident response process to identify and notify affected third-party providers as part of any incident involving their systems.

PL: Planning

PL is foundational rather than acutely risky on its own (similar to CC1 in the SOC 2 report), but it is the family that ties every other control family's documentation together for an external reviewer.

Control	Current State	Gap	Remediation
PL-2 System Security Plan (SSP)	No SSP currently exists. The SOC 2 report's system description (Section 1 of that report) covers similar ground but in AICPA format, not NIST format.	No consolidated document describing the system boundary, control implementation status, and responsible parties in NIST-expected format. Specifically missing: a formal security categorization with supporting rationale, a privacy risk assessment (Northstar processes customer PII), and a defined review/update cadence for the plan itself.	This engagement produces an initial SSP excerpt (Section 5.1) as the foundation; a full SSP should be completed and maintained going forward, including a security categorization, privacy risk assessment, and an annual review cycle.
PL-4 Rules of Behavior	Informal expectations communicated via onboarding conversations and the Access Control Policy.	No standalone Rules of Behavior document requiring signed employee acknowledgment.	Draft a short Rules of Behavior document and collect signed acknowledgment at onboarding and annually.
PL-4(1) Social Media & External Site Restrictions	No standalone Rules of Behavior document exists (see PL-4).	Even once a Rules of Behavior document is drafted, no specific restrictions on social media/external site usage, posting organizational information publicly, or using company-provided credentials to create external accounts have been considered.	When drafting the Rules of Behavior document, include explicit restrictions covering social media use, public posting of organizational information, and use of company email/credentials for third-party accounts.

RA: Risk Assessment

RA-5(2) (Update Vulnerabilities to Be Scanned) is not listed as a separate finding: it is the operational counterpart to RA-5's own requirement that scanning tools support readily updating what they scan for, and fails for the same reason and closes with the same remediation as the base RA-5 finding.

Control	Current State	Gap	Remediation
RA-3 Risk Assessment	A lightweight risk register was established under SOC 2 remediation (CC3), reviewed quarterly.	Risk register does not yet reflect the broader NIST-scoped risk landscape (only covers the original nine SOC 2 categories), and does not include a distinct determination of likelihood/impact of adverse effects on individuals from PII processing (same gap noted under PL-2).	Expand the existing risk register to incorporate findings from this NIST assessment (see Section 3), and add a specific privacy risk determination for PII processing activities.
RA-3(1) Supply Chain Risk Assessment	A Vendor Management Policy exists (SA-9) covering key vendors with initial risk tiering.	Vendor risk tiering has not been formally integrated into the risk register as a distinct supply chain risk category, and there is no defined process to reassess supply chain risk when a vendor or vendor relationship changes.	Formally link vendor risk tiering (SA-9) into the risk register as a supply-chain risk category, with a reassessment trigger tied to vendor changes.

Control	Current State	Gap	Remediation
RA-5 Vulnerability Monitoring	No vulnerability scanning tool currently in use.	No visibility into known vulnerabilities in dependencies, container images, or infrastructure.	Adopt a vulnerability scanning tool (e.g., AWS Inspector, or an open-source SCA tool in CI/CD) with a defined remediation SLA by severity.
RA-5(5) Privileged Access	No vulnerability scanning tool currently in use.	Even once a scanning tool is adopted, there is no plan to use privileged/authenticated access for scanning, which finds significantly more vulnerabilities than external, unauthenticated scans alone.	When selecting and configuring a vulnerability scanning tool, include authenticated scanning using a dedicated, tightly-scoped privileged scanning account.
RA-5(11) Public Disclosure Program	No public vulnerability disclosure channel exists.	No mechanism (e.g., a security.txt file, a dedicated email alias, or a formal bug bounty program) exists for external security researchers to report vulnerabilities they discover in Northstar's systems.	Publish a security.txt file and a dedicated security@ email alias as a lightweight, low-cost starting point for a public disclosure channel.

SA: System & Services Acquisition

Control	Current State	Gap	Remediation
SA-9 External System Services	A Vendor Management Policy exists covering AWS, Stripe, and Google Workspace (SOC 2 CC9 remediation), including an initial vendor inventory and risk tiering.	Policy has not yet been extended to evaluate vendors specifically against NIST-relevant criteria (e.g., data residency, incident notification SLAs in vendor contracts); internal oversight roles and responsibilities for managing external service providers are not formally documented; and vendor risk tiering reflects a point-in-time assessment rather than an ongoing compliance monitoring process.	Add a NIST-alignment checklist item to the existing vendor due-diligence process for High and Medium tier vendors; document internal ownership for vendor oversight; and define a recurring cadence (e.g., annual) to reverify vendor compliance.
SA-9(2) Identification of Functions, Ports, Protocols & Services	The Vendor Management Policy documents which vendors are used, but not their technical service footprint.	No requirement for vendors to identify the specific functions, ports, protocols, or services needed to deliver their service, limiting visibility into each vendor's technical attack surface.	Add a requirement to the vendor due-diligence process for High and Medium tier vendors to document the functions, ports, and protocols their service requires.

Control	Current State	Gap	Remediation
SA-15 Secure Development	Peer code review is required before merge (SOC 2 CC8).	No documented secure coding standard or dependency management policy (e.g., how third-party libraries are vetted before adoption); the specific standards and tools used in development (e.g., linters, dependency scanners, CI/CD configuration) are not documented, changes to the development process or tooling itself are not tracked, and there is no periodic review of whether current tools and standards still meet security requirements.	Draft a lightweight secure development policy covering code review, dependency vetting, and secrets management in code; document the specific tools/standards in use and require change control over CI/CD pipeline configuration; establish an annual review of the development process and tooling.
SA-15(3) Criticality Analysis	No criticality analysis has been performed on system components.	No process exists to identify which components are most critical to security or business function at key points in the development lifecycle (e.g., design, pre-release), so security review effort is not prioritized based on criticality.	Add a lightweight criticality analysis step (e.g., tagging components as high/medium/low criticality) at the design and pre-release stages of the development process.

SC: System & Communications Protection

Similar to the SOC 2 finding, this family shows Northstar's underlying AWS infrastructure already provides strong built-in protections. The gap is almost entirely documentation, not technology. Note that SC-12 (key management) and SC-13 (cryptographic protection) are distinct controls testing different things, determining and implementing the right type of cryptography versus managing the keys used by that cryptography, and are assessed separately here rather than combined.

Control	Current State	Gap	Remediation
SC-8 Trans mission Confidentiality	AWS-managed TLS is used for data in transit by default across the environment.	No documented network architecture or data flow diagram showing how data moves between components.	Produce a simple data flow diagram as part of the SSP (Section 5.1).
SC-8(1) Cryptographic Protection	AWS-managed TLS is used for data in transit by default across the environment.	None identified; existing TLS implementation already provides cryptographic protection against unauthorized disclosure and undetected modification in transit.	None required; maintain current TLS configuration as part of the SC-8 finding.

Control	Current State	Gap	Remediation
SC-13 Cryptographic Protection	AWS-managed encryption is used by default for data at rest (KMS on RDS/S3) and data in transit (TLS), based on AWS's default configuration.	No documented determination of the organization's required cryptographic uses (e.g., data at rest, data in transit, backups) or the specific type of cryptography required for each (e.g., AES-256, TLS 1.2+), relying on AWS defaults rather than a stated cryptography standard.	Document a brief cryptography standard naming each required use and the specific type/algorithm required (e.g., AES-256 via AWS KMS for data at rest, TLS 1.2+ for data in transit).
SC-12 Cryptographic Key Establishment & Management	AWS KMS manages encryption keys for RDS and S3 by default.	No documented key management policy describing key rotation frequency, key access restrictions, or key lifecycle procedures.	Document current AWS KMS usage and define a key rotation policy, including who can access or administer keys.

SI: System & Information Integrity

This is the second-largest gap area, largely overlapping with the unaddressed vulnerability-scanning and patch-management item already flagged, but not fully closed, in the SOC 2 report. SI-4(2) (Automated Tools for Real-time Analysis) is not listed separately: it is effectively what the recommended GuardDuty adoption already provides, and shares the same finding and remediation as the base SI-4 gap above.

Control	Current State	Gap	Remediation
SI-2 Flaw Remediation	No formal patch management process; the SOC 2 report flagged this as an open item that was not fully remediated.	No defined patch cadence or SLA by severity for operating systems, dependencies, or third-party libraries; no process to test updates for effectiveness or side effects prior to installation; and patch remediation is not integrated into the change management process addressed under CM-3.	Define a patch management SLA (e.g., critical within 7 days, high within 30) and assign ownership; require pre-installation testing where feasible; and fold patch deployment into the same change control process being established under CM-3.
SI-2(2) Automated Flaw Remediation Status	No formal patch management process exists.	No automated mechanism reports whether system components actually have applicable security updates installed, distinct from having a remediation process at all.	Once a patch management tool is selected, ensure it includes automated patch-status reporting, not just deployment.
SI-4 System Monitoring	CloudTrail and GitHub audit logging provide raw visibility.	No intrusion detection or anomaly-based monitoring beyond manual log review; monitoring objectives and escalation criteria for changing risk are undocumented; and no legal review of the organization's system monitoring activities (e.g., regarding employee privacy) has been obtained.	Adopt AWS GuardDuty (shared remediation with AU-6(1) above) for automated anomaly detection; document monitoring objectives and escalation criteria; and obtain a brief legal review of monitoring practices alongside the Access Control/Acceptable Use policies.

Control	Current State	Gap	Remediation
SI-4(4) Inbound & Outbound Communications Traffic	No dedicated network traffic monitoring beyond CloudTrail/GitHub log review.	No defined criteria for unusual or unauthorized inbound/outbound network traffic, and no monitoring specifically targeting communications traffic (as opposed to application/API-level events).	Enable AWS VPC Flow Logs and define criteria for unusual traffic patterns (e.g., unexpected destinations, high-volume outbound transfer).
SI-4(5) System-generated Alerts	No automated detection tooling currently in use.	Even once detection tooling (e.g., GuardDuty) is adopted, no defined routing exists to alert specific personnel when a compromise indicator is detected.	Configure GuardDuty (or equivalent) to route high-severity findings directly to the Incident Response Lead in real time, consistent with the AU-6(1) remediation.
SI-3 Malicious Code Protection	No endpoint protection requirement documented for employee devices.	Device security policy (SOC 2 Access Control Policy 3.6) covers encryption and screen lock but not malware protection; no malicious code protection mechanism exists at either endpoint or network entry/exit points, no automatic update process for such a mechanism, no defined scanning cadence, and no documented process for handling false positives without impacting system availability.	Extend the device security policy to require endpoint protection (with automatic signature updates and real-time scanning) on any device used to access production systems; consider complementary network-level protection at entry/exit points; and define a lightweight process for handling false positives.

3. Risk Register

Findings are ranked by likelihood and impact, consistent with the methodology used in the SOC 2 readiness report, so priorities are comparable across both engagements.

Priorit y	Family	Likelihood	Impact	Rationale
1	SI: Vulnerability Mgmt	High	High	No vulnerability scanning means unknown exposures persist indefinitely; this was already flagged in the SOC 2 report and remains unaddressed.
2	CP: Contingency Planning	Medium	High	A single backup test is not the same as a documented, tested recovery capability with defined RTO/RPO; an actual outage could still go poorly.
3	AT: Awareness Training	Medium	Medium	Untrained staff are the most common entry point for social engineering; low cost to fix relative to the risk it carries.
4	AC: Privileged Access	Medium	High	Base access hygiene is solid post-SOC-2, but unreviewed privileged accounts widen the blast radius of any single compromise.
5	CM: Configuration Baseline	Medium	Medium	Without a baseline, drift goes unnoticed and there's no reference point to detect unauthorized changes.
6	SA: Secure Development	Medium	Medium	Contained risk similar to the SOC 2 change-management finding; peer review helps, but dependency risk is unmanaged.
7	SC: Documentation	Low	Medium	Underlying technical protections (AWS-managed encryption/TLS) are strong; risk is limited to lack of documented evidence for a reviewer.
8	PL: System Security Plan	Low	Medium	Foundational rather than acutely risky, but required as the reference document this whole assessment builds toward.
9	IA: Identity Lifecycle	Low	Low	MFA and SSO already close most of the risk; remaining gap is periodic service-account review.
10	IR: Plan Testing	Low	Medium	The plan exists; risk is that it hasn't been exercised, so gaps in it are still unknown.
11	AU: Retention & Alerting	Low	Low	Logging exists and is reviewed monthly; gap is formalization, not absence of visibility.
12	RA: Formal Risk Process	Low	Low	A lightweight process already exists from SOC 2; this is a scope-expansion update, not a new risk.

4. Remediation Roadmap

Phase 1 = Weeks 1–3 (Quick Wins), Phase 2 = Weeks 4–8 (Core Buildout), Phase 3 = Weeks 9–12 (Documentation & Formalization). This roadmap picks up where the SOC 2 remediation left off. It does not re-schedule work already completed.

Phase	Family	Action	Owner	Target	Evidence Type
1	RA / SI	Adopt vulnerability scanning tool; define remediation SLA by severity.	Security Owner	Week 1	Scan tool config; documented SLA
1	AT	Roll out security awareness training to all staff.	Security Owner	Week 2	Training completion log
1	IR	Run first Incident Response tabletop exercise.	IR Lead + Team	Week 3	Tabletop after-action report
2	CP	Draft Contingency Plan with defined RTO/RPO; expand backup scope beyond primary database.	Security Owner + Founder	Week 5	Signed Contingency Plan document
2	CM	Document AWS configuration baseline; extend change policy to infrastructure changes.	Engineering Lead	Week 6	Baseline document; updated change policy
2	AC	Formalize least-privilege baselines by role; add privileged account review to monthly cadence.	Security Owner	Week 7	Role-based access matrix; review log
2	SI	Define patch management SLA; enable automated anomaly alerting (GuardDuty).	Engineering Lead	Week 8	Patch SLA document; alerting config
3	PL	Draft System Security Plan (SSP) and Rules of Behavior document.	Security Owner	Week 10	Signed SSP; signed RoB acknowledgments
3	SA	Draft secure development / dependency management policy.	Engineering Lead	Week 10	Policy document
3	SC	Produce data flow diagram; document key management/rotation policy.	Engineering Lead	Week 11	Diagram; key management policy
3	AU / RA	Finalize log retention policy; expand risk register to full NIST scope.	Security Owner	Week 12	Retention policy; updated risk register
3	All	Compile and finalize POA&M tracker for any remaining open items.	Security Owner	Week 12	Completed POA&M (Section 5.2)

5. Sample Artifacts

The two artifacts below are NIST-specific deliverables that were not part of the SOC 2 report (which delivered three full policies instead). Rather than duplicate those policies here, this section provides the SSP and POA&M formats a NIST-aligned engagement is expected to produce.

5.1 System Security Plan (SSP) Excerpt

A full SSP documents every control in scope. This excerpt shows the format for the system identification section and a sample of control implementation statements, sufficient to demonstrate the deliverable's structure.

1. System Identification

System Name	Northstar Application Platform
System Owner	Founder / designated Security Owner
Impact Level (FIPS 199)	Moderate (Confidentiality: Moderate, Integrity: Moderate, Availability: Low)
Environment	AWS (EC2, RDS, S3), GitHub (source control & CI/CD), Stripe (billing), SSO identity provider
Authorization Boundary	Production AWS environment and connected SaaS vendors handling customer data; excludes internal-only tooling

2. Sample Control Implementation Statements

Control	Implementation Status	Implementation Statement
AC-2	Partially Implemented	Account provisioning and deprovisioning follow a documented request/approval process. Deprovisioning occurs within 24 hours of departure. Quarterly recertification is planned but not yet implemented (see POA&M item AC-2-01).
IA-2	Implemented	Multi-factor authentication is enforced for all accounts with access to production systems, source code, or customer data, via the organization's SSO provider.
SC-12	Partially Implemented	Data at rest is encrypted using AWS-managed encryption (KMS) on all RDS and S3 resources. A formal key rotation policy is planned (see POA&M item SC-12-01).
CP-9	Partially Implemented	Automated backups are enabled for the primary RDS database and have been validated via a successful restore test. Backup coverage for other in-scope data stores is planned (see POA&M item CP-9-01).

5.2 Plan of Action & Milestones (POA&M) Template

The POA&M tracks every open gap identified in Section 2 through to closure. A sample of populated rows is shown below; the full tracker carries one row per open control.

POA&M ID	Control	Weakness	Milestone	Target Date	Status
AC-2-01	AC-2	No periodic account recertification.	Add quarterly recertification to monthly access review.	Week 7	Open
CP-9-01	CP-9	Backup coverage limited to primary database.	Document and validate backup coverage across all in-scope data stores.	Week 5	Open

POA&M ID	Control	Weakness	Milestone	Target Date	Status
RA-5-01	RA-5	No vulnerability scanning in place.	Deploy scanning tool; define remediation SLA.	Week 1	Open
PL-2-01	PL-2	No completed System Security Plan.	Finalize full SSP beyond this excerpt.	Week 10	Open

Prepared by Beth Gerharts. This report is a portfolio demonstration piece prepared for a fictional company and does not represent an actual audit, engagement, or authorization decision.